Natalyx MVP Fixes

Consolidated plan overview - fourteen coordinated work packages

L. Rhodes (plan owner) - A. Zhao (technical review requested)

2026-07-10

Contents

1 Purpose and review request **3**

2 Current position **3**

3 Architecture spine **3**

4 Work-package map **4**

5 Suggested ownership and reciprocal review **4**

6 Delivery sequence **5**

7 Programme gates **5**

8 Work-package details **6**

8.1 WP00: Preservation, cloud diagnosis, and PR reconciliation 6

8.2 WP01: CI and PostgreSQL evidence gate 7

8.3 WP02: Versioned migrations and readiness 8

8.4 WP03: Authentication, invitations, and resume 9

8.5 WP04: Node 0 workspace and paid-case separation 10

8.6 WP05: Node 0 Free, Pathfinder, and resume 11

8.7 WP06: Node 0 Complete and GC soft onboarding 12

8.8 WP07: Commercial configuration, enrollment, and promotion 13

8.9 WP08: Payments, invoices, credits, and refunds 14

8.10 WP09: Documents, active case, and provider handoffs 16

8.11 WP10: Intelligence, memory, proposals, and Ask safety 17

8.12 WP11: Learn release and design-system contract 18

8.13 WP12: Ask/Learn shell and mobile cutover 19

8.14 WP13: Deployment, cloud gates, and PHI readiness 20

9 Decisions requiring explicit resolution **21**

10 Review checklist **24**

1 Purpose and review request

This is a planning document for cleaning up the current Natalyx MVP delivery surface without losing useful work or compounding the present architecture. It consolidates the programme into fourteen bounded work packages and fifty suggested pull requests. The detailed Markdown and PDF plan for each work package is supplied separately in the `MVP Fixes` Drive folder.

The GitHub Project is deliberately benched until this plan is reviewed. Nothing in this document authorizes implementation, PR closure, branch cleanup, cloud changes, schema changes, payment activation, real-user use or PHI processing.

The requested decision is simple: confirm the package boundaries, amend any technical assumptions or PR splits that are wrong, and agree the ownership/review split before implementation begins.

2 Current position

Area	Current conclusion	Planning consequence
Live dev	The inspected endpoint returned ALB 503.	Treat live recovery and known-revision evidence as Gate A0, separate from green CI.
PR 122	Materially safer invitation/case-shell behavior, but not the final architecture.	Selectively salvage tests and hardening after Alan's review is captured.
PR 124	Valuable participant work, but it creates a paid-case-shaped record too early and weakens authorship/access boundaries.	Do not merge unchanged; port behavior into the workspace-first plan.
Node 0	Free exploration, Complete entitlement, commitment, payment and paid case are currently too entangled.	Separate their entities and state machines before expanding UI.
Commercial	The business-model document is design authority; no append-only money ledger or promotion authority exists yet.	Keep prices/terms versioned and processor-neutral; no redirect or raw webhook can promote a case.
Documents/PHI	Documents are metadata-only and the provider branch is unreviewed.	Keep synthetic-only through A2, approved PII at B1, and PHI blocked until formal B2.

3 Architecture spine

- Node 0 begins as a free workspace; opening it never creates a canonical paid case.
- Workspace, entitlement, commercial commitment, payment, case, invitation/claim, document and journey-stage lifecycles remain separate.
- Only `byos.workspace_promotion_authorized.v1` authorizes exactly one `enrollment_pending` case; browser redirects and raw processor callbacks never do.
- IP observations remain IP-attributed and provisional. GC confirmation appends a GC-authored revision; it never silently overwrites or upgrades the source.

- The app owns durable case truth, authorization and PHI policy. Intelligence returns advisory proposals only. Learn artifacts and design-system releases remain pinned repository contracts.
- PostgreSQL is production authority. Versioned, ordered migrations replace runtime DDL, with locking, checksums, expand/contract compatibility and forward repair.
- Real PII/PHI readiness is established by evidence gates and human acceptance, not by merge or deployment success.

4 Work-package map

WP	Work package	Suggested PRs	Proposed lead	Reviewer	Gate range
WP00	Preservation, cloud diagnosis, and PR reconciliation	1	Luke	Alan	Pre-A0
WP01	CI and PostgreSQL evidence gate	1	Alan	Luke	A0
WP02	Versioned migrations and readiness	4	Alan	Luke	A0, A1
WP03	Authentication, invitations, and resume	4	Alan	Luke	A1, A2
WP04	Node 0 workspace and paid-case separation	3	Alan	Luke	A1
WP05	Node 0 Free, Pathfinder, and resume	3	Luke	Alan	A1
WP06	Node 0 Complete and GC soft onboarding	3	Alan	Luke	A2
WP07	Commercial configuration, enrollment, and promotion	4	Luke	Alan	A2
WP08	Payments, invoices, credits, and refunds	4	Luke	Alan	A2
WP09	Documents, active case, and provider handoffs	5	Alan	Luke	A2
WP10	Intelligence, memory, proposals, and Ask safety	4	Alan	Luke	A2
WP11	Learn release and design-system contract	4	Luke	Alan	A1, A2
WP12	Ask/Learn shell and mobile cutover	3	Luke	Alan	A2, B1
WP13	Deployment, cloud gates, and PHI readiness	7	Alan	Luke	A0, A1, A2, B2

5 Suggested ownership and reciprocal review

This is the proposed working split for discussion, chosen to keep product/commercial/content-heavy work with Luke and foundation/security/data/runtime work with Alan while retaining reciprocal review:

Lead	Work packages	Primary responsibility	Review partner
Luke	WP00, WP05, WP07, WP08, WP11, WP12	Programme reconciliation; Node 0 Free product boundary; commercial/payment contracts; Learn/design-system release; participant shell/cutover.	Alan reviews technical architecture, migration, security and failure behavior.
Alan	WP01, WP02, WP03, WP04, WP06, WP09, WP10, WP13	CI/PostgreSQL; migrations; auth/invitations; workspace/case model; GC onboarding; documents/provider handoff; intelligence; deployment/gates.	Luke reviews product, privacy, commercial, role, truth and release acceptance.

External security, privacy, payment, finance, legal, accessibility or provider review remains mandatory where the detailed package names it. The split can be amended before implementation; it is not an assignment imposed by the plan.

6 Delivery sequence

Phase	Work	Can run in parallel	Exit condition
Approval	WP00 plan review and PR 122/124 reconciliation	No implementation	Luke and Alan accept or explicitly amend the package boundaries.
Foundation	WP01, WP02 and A0 portions of WP13	Learn/DS source work in WP11	Current tests run on PostgreSQL; migration ADR/runner and known-revision recovery evidence are accepted.
Identity and domain	WP03 and WP04	Selected WP10 contract work	Claims/invitations are safe and Node 0 workspace is distinct from paid case.
Participant core	WP05 and WP06	Commercial configuration in WP07	Free and Complete flows are resumable, attributable and role-scoped.
Commercial and operations	WP07, WP08, WP09 and WP10	Separate repositories can progress behind pinned contracts	Synthetic A2 covers promotion, money, documents, proposals and failure recovery.
Release and cutover	WP11, WP12 and remaining WP13	Evidence collection across repos	A1/A2 pass; B1/B2 remain separately controlled human gates.

7 Programme gates

Gate	Purpose	Owner	Verifier	Failure rule
A0	Infrastructure recovery and known-revision health	Alan	Luke	Do not proceed to participant validation. Freeze live updates, retain evidence, restore the known compatible image/schema or forward-repair under the approved runbook, and keep the Project gate blocked.
A1	Synthetic core participant journey	Alan	Luke	Stop before Complete, commercial or paid-case validation. Revert/disable the failing participant feature flag or deploy the known A0 revision; preserve synthetic data only for defect diagnosis, then purge under the runbook.
A2	Synthetic commercial, promotion, billing and document journey	Alan	Luke	Disable commercial/document/provider features, retain free/safety content, prevent live money or real documents, reconcile synthetic ledger inconsistencies, and restore the A1-known revision or forward-repair as approved.
B1	Real-user and PII beta readiness	Luke	External/TBD	No real-user invitation. Continue synthetic-only, close control gaps, invalidate stale evidence and re-run the exact affected reviews/tests before a new go/no-go.
B2	PHI readiness and formal go/no-go	Luke	External security/privacy/compliance reviewers	PHI remains prohibited. Keep B1 PII scope only if still independently valid; disable any PHI-capable upload/context path, remediate, and repeat formal review.

8 Work-package details

8.1 WP00: Preservation, cloud diagnosis, and PR reconciliation

Problem. The live app is returning ALB 503 responses while overlapping draft PRs and protected dirty worktrees contain useful but contradictory implementations.

Target outcome. A signed-off source-of-truth baseline, complete extraction ledger, Alan-review reconciliation, and explicit no-delete/no-close conditions before replacement work begins.

Proposed lead/review. Luke leads; Alan reviews. The split is proposed for joint review and can be amended before implementation begins.

Key boundaries.

- Treat every existing branch and worktree as read-only evidence until its valuable files, tests, and

reviewer findings have a named destination.
- Use the organisation Project as the programme control plane and this repository-neutral package as the reviewable contract.
- Do not infer live health from GitHub build success; Gate A0 requires a known revision and live evidence.

PR	Repository	Suggested change	Depends on	Gate
P00-01	NatalyxPlatform/.github	Approve programme baseline and extraction ledger	None	Pre-A0

Acceptance focus.

- SHA and timestamp reproducibility
- Drive package/document identifier parity
- No dirty-worktree mutation
- HTTP and workflow evidence captured separately

Primary risks.

- Review findings arrive after decomposition
- A protected worktree contains the only copy of useful code
- A green PR is mistaken for live readiness

Full implementation contract: `WP00 - Preservation, cloud diagnosis, and PR reconciliation.md` in `MD Work Packages`; matching review PDF in `PDF Work Packages`.

8.2 WP01: CI and PostgreSQL evidence gate

Problem. Main builds containers and runs a deploy-contract smoke, but does not run the Python suite or prove current schema behavior against PostgreSQL.

Target outcome. A first, deliberately CI-only PR that runs the current tests, exercises the existing schema on PostgreSQL, and publishes diagnosable evidence without introducing the future migration framework.

Proposed lead/review. Alan leads; Luke reviews. Technical evidence foundation.

Key boundaries.

- PostgreSQL is production authority; SQLite remains a local compatibility target, not production evidence.
- Separate current-schema evidence from tests that require the future migration mechanism.

PR	Repository	Suggested change	Depends on	Gate
P01-01	NatalyxPlatform/natalyx-app	Establish current-test and PostgreSQL CI evidence	P00-01	A0

Acceptance focus.

- Current unit suite
- Fresh PostgreSQL database
- Current init_db idempotency
- Failure artifact and log clarity

Primary risks.

- CI exposes existing backend drift
- Tests accidentally depend on protected branch code
- Secrets or DB credentials leak in logs

Full implementation contract: `WP01 - CI and PostgreSQL evidence gate.md` in `MD Work Packages`; matching review PDF in `PDF Work Packages`.

8.3 WP02: Versioned migrations and readiness

Problem. Startup calls a monolithic CREATE/ALTER routine without an ordered migration ledger, advisory lock, expand/contract contract, or reliable partial-failure recovery.

Target outcome. An approved migration ADR, versioned runner, production-safe locking/readiness behavior, baseline migration, and forward-repair procedure proven on PostgreSQL and compatible with supported SQLite development.

Proposed lead/review. Alan leads; Luke reviews. Alan proposes framework; Luke approves compatibility/risk.

Key boundaries.

- Alan evaluates Alembic versus a custom ordered runner; a custom runner is not the default without ADR evidence.
- Migrations are forward-only by default, transaction-scoped where PostgreSQL permits, advisory-locked, checksum-recorded, and expand/contract compatible with the previous app revision.

PR	Repository	Suggested change	Depends on	Gate
P02-01	NatalyxPlatform/natalyx-app	Decide migration architecture and compatibility contract	P01-01	A0

PR	Repository	Suggested change	Depends on	Gate
P02-02	NatalyxPlatform/natalyx-app	Introduce versioned migration runner and readiness checks	P02-01	A0
P02-03	NatalyxPlatform/natalyx-app	Baseline canonical schema and prove expand-contract repair	P02-02	A1
P02-04	NatalyxPlatform/natalyx-intelligence	Move intelligence persistence to a revisioned migration namespace	P02-01, P02-02	A1

Acceptance focus.

- Fresh and upgraded PostgreSQL
- Concurrent migrators
- Old/new app compatibility
- Interrupted migration and forward repair
- SQLite support decision

Primary risks.

- Irreversible DDL
- Concurrent deploy race
- Long backfill lock
- SQLite semantics hide PostgreSQL failure

Full implementation contract: `WP02 - Versioned migrations and readiness.md` in `MD Work Packages`; matching review PDF in `PDF Work Packages`.

8.4 WP03: Authentication, invitations, and resume

Problem. Current invitation code mixes low-risk onboarding links with case membership, and existing flows need explicit recipient binding, return-to safety, consent, expiry, revocation, duplicate-claim, and mismatch semantics.

Target outcome. Separate workspace-claim and paid-case invitation lifecycles with safe authentication/resume behavior and no link-possession path to sensitive case access.

Proposed lead/review. Alan leads; Luke reviews. Luke decides admission/access policy.

Key boundaries.

- An email-less link may create a pending low-risk workspace claim only.
- Paid-case membership requires authenticated identity binding, recipient or issuer confirmation as appropriate, explicit consent, and auditable redemption.
- Return targets are internal allowlisted paths and survive login/signup/confirmation without becoming redirect authority.

PR	Repository	Suggested change	Depends on	Gate
P03-01	NatalyxPlatform/natalyx-app	Harden auth return-to and participant resume	P01-01	A1
P03-02	NatalyxPlatform/natalyx-app	Add low-risk workspace claim lifecycle	P03-01, P04-01	A1
P03-03	NatalyxPlatform/natalyx-app	Bind paid-case invitations to identity and consent	P03-01, P04-01	A2
P03-04	NatalyxPlatform/natalyx-infra	Replace shared signup admission with claim-aware Cognito admission	P03-02, P03-03	A1

Acceptance focus.

- Logged-out resume
- Token replay/expiry/revocation
- Duplicate and concurrent claims
- Identity mismatch
- Workspace-to-case access escalation

Primary risks.

- Shared links forwarded
- Account mismatch
- Confused-deputy redirects
- Workspace data exposed during upgrade

Full implementation contract: `WP03 - Authentication, invitations, and resume.md` in `MD Work Packages`; matching review PDF in `PDF Work Packages`.

8.5 WP04: Node 0 workspace and paid-case separation

Problem. PR #124 creates a synthetic canonical case as soon as Node 0 is opened, collapsing free exploration, workspace membership, commercial commitment, and paid-case truth.

Target outcome. A distinct Node 0 workspace aggregate with attributable revisions and an idempotent, purpose-limited projection into one paid case only after the authorized commercial event.

Proposed lead/review. Alan leads; Luke reviews. Joint domain/provenance design.

Key boundaries.

- Workspace, entitlement, commercial, payment, and case lifecycles are separate entities and state machines.
- Promotion copies only allowlisted projections with provenance, visibility, and verification intact.

- Compatibility adapters read old case-shaped Node 0 records while new writes target the workspace model.

PR	Repository	Suggested change	Depends on	Gate
P04-01	NatalyxPlatform/natalyx-app	Separate Node 0 workspace storage from paid cases	P02-03	A1
P04-02	NatalyxPlatform/natalyx-app	Add attributable workspace revision and projection contracts	P04-01	A1
P04-03	NatalyxPlatform/natalyx-app	Adapt legacy Node 0 case-shaped data without semantic promotion	P04-02	A1

Acceptance focus.

- One workspace/one promotion
- Retry/concurrency
- No implicit fact upgrade
- Private candidate isolation
- Old/new revision coexistence

Primary risks.

- Semantic data corruption during backfill
- Duplicate cases
- Private candidate leakage
- Older app revision writes legacy shape

Full implementation contract: `WP04 - Node 0 workspace and paid-case separation.md` in `MD Work Packages`; matching review PDF in `PDF Work Packages`.

8.6 WP05: Node 0 Free, Pathfinder, and resume

Problem. Pathfinder contains service/LLM-era routing complexity and Node 0 Free must satisfy the complete-the-match boundary without payment while preserving explicit IP authorship.

Target outcome. A deterministic entry router and resumable Node 0 Free flow for education, candidate tracking, preliminary safety checks, outreach guidance, and a willing candidate without a paid case.

Proposed lead/review. Luke leads; Alan reviews. The split is proposed for joint review and can be amended before implementation begins.

Key boundaries.

- Routing is deterministic policy, not LLM authority.
- Candidate responses are provisional IP assertions, never GC-authored or medically verified facts.
- Safety-critical information and complete-the-match capability remain free.

PR	Repository	Suggested change	Depends on	Gate
P05-01	NatalyxPlatform/natalyx-app	Replace Pathfinder routing with deterministic entry decisions	P03-01, P04-01	A1
P05-02	NatalyxPlatform/natalyx-app	Rebuild Node 0 Free candidate and outreach domain	P04-02, P05-01	A1
P05-03	NatalyxPlatform/natalyx-app	Ship resumable Node 0 Free participant surface	P03-01, P05-02, P11-03	A1

Acceptance focus.

- All deterministic route outcomes
- Free candidate/outreach boundary
- Resume across sessions
- Critical-flag fail-safe
- Mobile interaction

Primary risks.

- Paid features leak into Free
- Provisional score is overclaimed
- Route drift
- LLM dependency reintroduced

Full implementation contract: `WP05 - Node 0 Free, Pathfinder, and resume.md` in `MD Work Packages`; matching review PDF in `PDF Work Packages`.

8.7 WP06: Node 0 Complete and GC soft onboarding

Problem. Optional paid depth, GC soft onboarding, and readiness reporting need clear entitlement gates without creating a managed case or treating IP assertions as GC answers.

Target outcome. Versioned Node 0 Complete entitlement, authenticated low-risk GC onboarding, attributable GC confirmation/replacement, and a readiness report that remains preliminary.

Proposed lead/review. Alan leads; Luke reviews. Luke owns cross-role projection and Complete contract.

Key boundaries.

- Node 0 Complete is a flat configurable entitlement fully creditable against the JMF.

- GC confirmation appends an attributable revision; it never silently overwrites the IP source.
- GC-private answers stay private; only explicit purpose-limited projections reach the IP.

PR	Repository	Suggested change	Depends on	Gate
P06-01	NatalyxPlatform/natalyx-app	Add Node 0 Complete entitlement and versioned feature gates	P04-01, P07-01, P08-01	A2
P06-02	NatalyxPlatform/natalyx-app	Add GC soft onboarding and attributable confirmation	P03-02, P04-02, P06-01	A2
P06-03	NatalyxPlatform/natalyx-app	Add readiness report and role-scoped progress surfaces	P06-02, P10-02, P11-04	A2

Acceptance focus.

- Entitlement versioning
- GC-authored revisions
- IP/GC visibility pairs
- Revoked/expired claims
- No paid-case creation

Primary risks.

- Entitlement mistaken for case access
- GC answers exposed to IP
- IP assertions silently converted
- Price hard-coded

Full implementation contract: `WP06 - Node 0 Complete and GC soft onboarding.md` in `MD Work Packages`; matching review PDF in `PDF Work Packages`.

8.8 WP07: Commercial configuration, enrollment, and promotion

Problem. The business model requires versioned price/terms, explicit commitment, and one precise processor-neutral event before workspace-to-case promotion; none is currently authoritative.

Target outcome. Versioned commercial configuration and acceptances, a separate commitment/enrollment lifecycle, one processor-neutral byos.workspace_promotion_authorized.v1 event, and exactly-once paid-case creation by its consumer.

Proposed lead/review. Luke leads; Alan reviews. The split is proposed for joint review and can be amended before implementation begins.

Key boundaries.

- Every commitment, invoice, payment, credit, refund, and promotion records the activated commercial-configuration version.
- Only the app-owned commitment/commercial domain emits byos.workspace_promotion_authorized.v1 after durable funding/terms/credit validation; a processor callback or redirect never emits it.
- The consumer creates/fetches one enrollment_pending case and restricted IP membership; GC case access follows the paid-case invitation contract.

PR	Repository	Suggested change	Depends on	Gate
P07-01	NatalyxPlatform/natalyx-app	Add versioned commercial configuration and terms acceptance	P02-03	A2
P07-02	NatalyxPlatform/natalyx-app	Implement commitment and enrollment-pending lifecycle	P07-01, P08-01	A2
P07-03	NatalyxPlatform/natalyx-app	Emit processor-neutral workspace promotion authorization	P04-02, P07-02, P08-02	A2
P07-04	NatalyxPlatform/natalyx-app	Promote workspace exactly once from authorization event	P03-03, P04-02, P07-03	A2

Acceptance focus.

- Terms/config version pinning
- Commitment retries
- Exact-once promotion
- Funding reversal handling
- No GC access escalation

Primary risks.

- Configuration drift
- Duplicate promotion
- Redirect spoofing
- Unresolved policy encoded as default

Full implementation contract: `WP07 - Commercial configuration, enrollment, and promotion.md` in `MD Work Packages`; matching review PDF in `PDF Work Packages`.

8.9 WP08: Payments, invoices, credits, and refunds

Problem. No append-only commercial ledger or processor-neutral payment boundary currently supports the $8,900 JMF, $750 enrollment, Node 0 credit, milestones, deterministic refunds, or failure recovery.

Target outcome. Immutable commercial ledgers, idempotent provider inbox, milestone engine, reproducible credits/refunds, reconciliation, and safe non-critical pause behavior.

Proposed lead/review. Luke leads; Alan reviews. The split is proposed for joint review and can be amended before implementation begins.

Key boundaries.

- Payments, credits, refunds, adjustments, invoices, and commercial events are append-only; mutable balances are derived projections.
- Processor events enter an idempotent inbox and become internal commands/events only after signature and amount/currency checks.
- Billing follows durable case evidence and never acts as first notification of clinical events.

PR	Repository	Suggested change	Depends on	Gate
P08-01	NatalyxPlatform/natalyx-app	Add append-only commercial and money ledgers	P02-03, P07-01	A2
P08-02	NatalyxPlatform/natalyx-app	Add processor-neutral payment command and webhook inbox	P08-01, P07-02	A2
P08-03	NatalyxPlatform/natalyx-app	Implement milestone invoicing, credits, and deterministic refunds	P08-02, P07-04, P09-04	A2
P08-04	NatalyxPlatform/natalyx-app	Add payment reconciliation and safe service-pause operations	P08-03	A2

Acceptance focus.

- Webhook replay/order
- Ledger invariants
- Milestone idempotency
- Refund table
- Node 0 credit floor
- Reconciliation mismatch

Primary risks.

- Double charge/refund
- Processor lock-in
- Clinical timing harm
- Pass-through commingling
- Policy gaps

Full implementation contract: `WP08 - Payments, invoices, credits, and refunds.md` in `MD Work Packages`; matching review PDF in `PDF Work Packages`.

8.10 WP09: Documents, active case, and provider handoffs

Problem. Current documents are metadata-only; the dirty provider branch is unreviewed and can over-project facts. There is no durable private S3/KMS/quarantine/recovery pipeline.

Target outcome. A secure document lifecycle, resilient storage/scan/download pipeline, usable active-case surfaces, and consent-scoped immutable provider snapshots with operational review.

Proposed lead/review. Alan leads; Luke reviews. Luke approves retention and provider purpose.

Key boundaries.

- Private bucket, block-public-access, KMS, opaque keys, application authorization, size/type/checksum gates, quarantine/scan, audit, retention, and orphan cleanup are mandatory.
- Provider handoffs are purpose-bound snapshots with checksum/revision/expiry and consent; provider-visible items are allowlisted, not inferred from broad visibility.
- ECS replacement must not lose upload/task state; recovery resumes from durable metadata and object state.

PR	Repository	Suggested change	Depends on	Gate
P09-01	NatalyxPlatform/natalyx-app	Define document lifecycle, authorization, and retention contract	P00-01, P02-01	A2
P09-02	NatalyxPlatform/natalyx-infra	Provision private encrypted document and quarantine storage	P09-01, P13-02	A2
P09-03	NatalyxPlatform/natalyx-app	Implement resilient document upload, scan, and download	P09-02, P02-03	A2
P09-04	NatalyxPlatform/natalyx-app	Complete active-case participant document and progress surfaces	P03-03, P07-04, P09-03, P11-03	A2
P09-05	NatalyxPlatform/natalyx-app	Implement consent-scoped provider handoff snapshots and operations	P04-02, P09-03, P09-04, P10-02	A2

Acceptance focus.

- Unauthorized object access
- Oversize/type/spoof
- Scan failure/quarantine
- Partial upload/task loss
- Snapshot immutability/revocation
- Mobile documents

Primary risks.

- PHI exposure
- Malware
- Orphaned objects
- Stale provider packet
- Dirty branch leakage

Full implementation contract: `WP09 - Documents, active case, and provider handoffs.md` in `MD Work Packages`; matching review PDF in `PDF Work Packages`.

8.11 WP10: Intelligence, memory, proposals, and Ask safety

Problem. Private memory, shared case truth, Learn context, and AI proposals have partial contracts but current app code can place IP guide notes into shared memory and provider projections lack provenance enforcement.

Target outcome. Versioned scoped context envelopes, separate private/shared memory revisions, evidence-bound proposal approval, grounded Ask behavior, and cross-service safety evaluation/observability.

Proposed lead/review. Alan leads; Luke reviews. Luke approves truth/scope policy.

Key boundaries.

- The app owns case truth, authorization, PHI policy, and durable approval; intelligence returns advisory proposals only.
- Every request declares general Learn, private-user, approved-shared-case, or provider-purpose scope; contexts are not merged.
- Failures degrade explicitly with source/boundary notices and no fabricated case answer.

PR	Repository	Suggested change	Depends on	Gate
P10-01	NatalyxPlatform/natalyx-intelligence	Version the scoped intelligence context envelope	P01-01, P04-02	A2
P10-02	NatalyxPlatform/natalyx-app	Enforce private/shared memory and evidence-bound proposal approval	P04-02, P10-01	A2
P10-03	NatalyxPlatform/natalyx-intelligence	Harden Ask and Learn grounding and degraded-mode behavior	P10-01, P11-02	A2
P10-04	NatalyxPlatform/natalyx-intelligence	Add intelligence safety evaluations and cross-service observability	P10-02, P10-03	A2

Acceptance focus.

- Scope isolation
- Proposal approval/rejection
- Citation/source validity
- Unavailable service
- Prompt/context leakage
- Trace redaction

Primary risks.

- Private-to-shared leakage
- Hallucinated truth
- Sensitive logs
- Contract version drift

Full implementation contract: `WP10 - Intelligence, memory, proposals, and Ask safety.md` in `MD Work Packages`; matching review PDF in `PDF Work Packages`.

8.12 WP11: Learn release and design-system contract

Problem. Learn artifact generation and catalog work is dirty/unreleased, while participant surfaces need governed recipes without making aesthetic purity a universal release gate.

Target outcome. Validated provenance-bearing Learn artifacts, approved-only serving, release-blocking DS accessibility/security/interaction contract, and app adoption of stable recipes/source cards.

Proposed lead/review. Luke leads; Alan reviews. The split is proposed for joint review and can be amended before implementation begins.

Key boundaries.

- Learn resources own authored artifacts/provenance; intelligence owns approved catalog delivery; app owns authorized presentation and context.
- Security, accessibility, responsive layout, and interaction defects can block release; token/style purity alone is backlog unless tied to concrete risk.
- Participant and internal/operator design systems remain separate.

PR	Repository	Suggested change	Depends on	Gate
P11-01	NatalyxPlatform/natalyx-learn-resources	Publish validated Learn artifact and provenance contract	P00-01	A2
P11-02	NatalyxPlatform/natalyx-intelligence	Serve approved Learn catalog versions from intelligence	P11-01	A2
P11-03	NatalyxPlatform/natalyx-design-system	Release participant design-system accessibility and interaction contract	P00-01	A1

PR	Repository	Suggested change	Depends on	Gate
P11-04	NatalyxPlatform/natalyx-app	Adopt approved Learn and source-card recipes in app	P11-02, P11-03	A2

Acceptance focus.

- Artifact schema/provenance
- Approved-only catalog
- Missing-resource empty state
- Recipe escaping
- Keyboard/reduced-motion/mobile

Primary risks.

- Fake/unapproved content
- Cross-repo version drift
- Aesthetic review blocks recovery
- Internal DS leakage

Full implementation contract: `WP11 - Learn release and design-system contract.md` in `MD Work Packages`; matching review PDF in `PDF Work Packages`.

8.13 WP12: Ask/Learn shell and mobile cutover

Problem. Participant Ask/Learn entry points, case shell, legacy routes, and mobile interactions are not yet one coherent clickable journey with explicit context boundaries.

Target outcome. A unified scope-labelled Ask/Learn shell, accessible mobile participant journey, and verified redirect-based legacy cutover with no broken or misleading controls.

Proposed lead/review. Luke leads; Alan reviews. The split is proposed for joint review and can be amended before implementation begins.

Key boundaries.

- The shell labels general, private, and shared-case context and never implies a source exists when it does not.
- Server owns state and permissions; client code enhances interaction only.
- Legacy routes redirect through allowlisted, telemetry-observed compatibility paths before deletion.

PR	Repository	Suggested change	Depends on	Gate
P12-01	NatalyxPlatform/natalyx-app	Unify Ask and Learn shell with explicit context scopes	P10-03, P11-04, P09-04	A2
P12-02	NatalyxPlatform/natalyx-app	Complete mobile participant interaction and accessibility cutover	P05-03, P06-03, P09-04, P12-01	A2
P12-03	NatalyxPlatform/natalyx-app	Retire legacy participant routes behind verified redirects	P12-02, P13-04	B1

Acceptance focus.

- Clickable IP/GC flows
- Context labels
- No-JS/reduced-motion/keyboard
- Mobile widths
- Redirect and stale bookmark
- Logout/login/resume

Primary risks.

- Context ambiguity
- Mobile-only dead ends
- Premature legacy removal
- Design drift

Full implementation contract: `WP12 - Ask and Learn shell and mobile cutover.md` in `MD Work Packages`; matching review PDF in `PDF Work Packages`.

8.14 WP13: Deployment, cloud gates, and PHI readiness

Problem. The dev endpoint is presently 503, deployments do not prove application readiness, and test/deploy success cannot establish real-user or PHI readiness.

Target outcome. Known-revision diagnostics, guarded rollback/evidence capture, automated synthetic A1/A2 journeys, and explicit B1/B2 operational/privacy/PHI go/no-go packets.

Proposed lead/review. Alan leads; Luke reviews. Alan verifies technical gates; Luke accepts; B1/B2 need independent review.

Key boundaries.

- Health, readiness, revision, dependency, migration, and safe configuration signals are distinct.
- Every cloud gate has prerequisites, evidence, owner, verifier, and failure/rollback response.
- B2 requires formal security/privacy/compliance evidence and human go/no-go; it is not a software test result.

PR	Repository	Suggested change	Depends on	Gate
P13-01	NatalyxPlatform/natalyx-app	Expose known-revision health, readiness, and dependency diagnostics	P01-01	A0
P13-02	NatalyxPlatform/natalyx-infra	Harden guarded deployment, rollback, and evidence capture	P01-01, P13-01	A0
P13-03	NatalyxPlatform/natalyx-app	Automate synthetic A1 core participant journey verification	P03-02, P04-03, P05-03, P11-03, P13-02	A1
P13-04	NatalyxPlatform/natalyx-app	Automate synthetic A2 commercial and document journey verification	P06-03, P07-04, P08-04, P09-05, P10-04, P12-02, P13-03	A2
P13-05	NatalyxPlatform/natalyx-app	Enforce case RLS and a non-owner PostgreSQL runtime	P02-03, P03-03, P04-03, P09-05, P10-02	B2
P13-06	NatalyxPlatform/natalyx-infra	Harden B1/B2 backups, audit, alarms, and cohort controls	P09-02, P13-02, P13-05	B2
P13-07	NatalyxPlatform/.github	Publish B1 and B2 privacy, PHI, and operational go-no-go runbooks	P13-04, P13-05, P13-06	B2

Acceptance focus.

- Known revision
- ALB/ECS/dependency health
- Rollback
- Synthetic A1/A2
- PII controls
- PHI go/no-go evidence

Primary risks.

- Unknown running revision
- Rollback incompatible with schema
- Synthetic success overclaimed
- PHI enabled without organizational controls

Full implementation contract: `WP13 - Deployment, cloud gates, and PHI readiness.md` in `MD Work Packages`; matching review PDF in `PDF Work Packages`.

9 Decisions requiring explicit resolution

Decision	Topic	Owner	Resolve by	Recommendation
D-MIG-01	Migration framework and SQLite support	Luke	Before P02-02	Prefer an established framework unless the ADR proves current SQL compatibility makes it unsafe or disproportionate.
D-AUTH-01	Workspace claim and paid-case identity policy	Luke	Before P03-02	Link possession creates pending workspace claim only; paid-case access always requires authenticated binding and explicit consent.
D-AUTH-02	Claim-aware Cognito admission mechanism	Luke	Before P03-04	Bind proof to email, purpose, claim ID and expiry; it admits account creation only and never grants workspace/case membership.
D-DATA-01	IP-GC field projection allowlist	Luke	Before P04-02	Default deny; expose only explicit purpose-limited projections. Class 1/2 and class 4 never automatically cross roles.
D-DATA-02	Correction, supersession and unselected-candidate retention	Luke	Before P04-02	Append revisions with supersedes/derived-from; never silently erase source; shortest justified retention for unselected candidates.
D-DATA-03	Candidate scoring and sensitive preference policy	Luke	Before P05-02	Remove candidate ranking and race preference; use source-labelled questions-to-clarify. Unverified IP answers cannot gate claim/onboarding/eligibility.
D-COM-01	Node 0 Complete price	Luke	Before activation of a Complete configuration	Keep no active production value until explicitly approved; test with synthetic configuration.
D-COM-02	Ratify JMF price book and effective date	Luke	Before P07-01 activation data	Use the document anchors but require explicit version activation rather than code literals.
D-COM-03	Terms, privacy and refund language versions	Luke	Before P07-02 user acceptance	External legal/privacy/finance review before any real acceptance.
D-COM-04	Enrollment funding and activation evidence	Luke	Before P07-02	Funding confirmation is durable ledger evidence; promotion uses the sole typed authorization event; activation requires an explicit evidence checklist, actor and audit event.
D-PAY-01	Payment processor and card/ACH scope	Luke	Before P08-02 adapter	Choose only after domain/ledger contract; retain processor-neutral ports.

Decision	Topic	Owner	Resolve by	Recommendation
D-COM-05	Financing path	Luke	Before financed option is exposed	Do not block card/ACH MVP; keep optional and disabled.
D-COM-06	Pregnancy-loss credit or retained-revenue policy	Luke	Before automated pregnancy-stage refund logic	Manual/counsel-reviewed hook until policy is approved; never hard-code.
D-COM-07	Cancellation and non-clearance policy sign-off	Luke	Before real billing	Use document schedule as test anchor; require legal/finance approval for live policy.
D-COM-08	Grace period and non-critical service pause	Luke	Before P08-04	Default to continued safety and entitled-document access; pause only clearly non-critical future services.
D-DOC-01	Document retention, deletion, replacement and download mode	Luke	Before P09-03	Purpose/role authorization independent of key; short-lived downloads; deletion tombstone/audit; legal/privacy review.
D-DOC-02	Document limits and malware/quarantine provider	Luke	Before P09-02	Narrow allowlist, checksum and content sniffing; unavailable scanner remains quarantined.
D-PROV-01	Provider handoff purposes and field allowlists	Luke	Before P09-05	Class 1/2 excluded; class 4 only if GC explicitly selects for recipient/purpose; class 5 evidence linked.
D-AI-01	Intelligence context and approval authority matrix	Luke	Before P10-01	Generic case members cannot create reviewed/provider truth; intelligence remains advisory and scope explicit.
D-OPS-01	Known-good recovery revision and rollback sequence	Luke	Before Gate A0 recovery action	Use a tested immutable image and compatible schema; do not deploy from dirty or draft branches.
D-PHI-01	PII/PHI boundary, vendors and control set	Luke	Before B1 for PII scope; before B2 for PHI	B1 remains PII-only; B2 requires formal external security/privacy/compliance evidence.
D-PHI-02	B1/B2 approvers and evidence expiry	Luke	Before B1	Luke is product go/no-go; independent qualified reviewers own their control attestations.

10 Review checklist

- Are the fourteen work-package boundaries correct, or should any be split, merged or reordered?
- Are the fifty suggested PRs small enough and assigned to the correct repositories?
- Are the workspace/case, invitation, authorship, promotion, payment, document and intelligence contracts technically sound?
- Is the proposed Luke/Alan lead split workable, with reciprocal review as stated?
- Are Alan's outstanding PR 122/124 findings fully represented, and what amendments do they require?
- Do any A0/A1/A2/B1/B2 acceptance criteria or external-review requirements need changing?
- No implementation begins until amendments are incorporated and the plan is jointly accepted.